

Project code: FUTURE_CS_02

• **Intern ID:** FUTURE_CS_01

PHISHING DETECTION & AWARENESS REPORT

Prepared by: Yushen Ramsamy

CIN: FIT/FEB26/CS6437

Date: 12 March 2026

Executive Summary & Introduction

Executive Summary

Phishing remains one of the most persistent and successful attack vectors in modern cybersecurity because it targets the "human element" rather than system vulnerabilities. This report details a technical analysis of three real-world phishing samples, identifying critical failures in email authentication protocols specifically **SPF, DKIM, and DMARC**. The goal of this audit is to provide clear risk classifications and actionable prevention guidelines to harden the organization's defence against social engineering and credential theft.

Introduction

The objective of this task was to act as a **Security Analyst** to evaluate the threat level of various suspicious emails. By utilizing forensic tools like the **Google Admin Toolbox Messageheader**, I was able to look past the visual "mask" of these emails and analyse their technical routing and origin.

Phishing attacks are typically designed to:

- **Steal Credentials:** Trick users into entering login details on fake portals.
- **Deliver Malware:** Encourage the download of infected attachments or "invoices".
- **Fraudulent Financial Gain:** Manipulate users into unauthorized wire transfers or "partnerships".

Technical Analysis

Sample 1: Banking Credential Harvesting

Google Admin Toolbox	Messageheader	Help
MessageId	20230919183549.39DEA3F725@ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06	
Created at:	9/19/2023, 8:35:49 PM GMT+2 (Delivered after 56 sec)	
From:	BANCO DO BRADESCO LIVELo<banco.bradesco@atendimento.com.br>	
To:	phishing@pot	
Subject:	CLIENTE PRIME - BRADESCO LIVELo: Seu cartão tem 92.990 pontos LIVELo expirando hoje!	
SPF:	temperror with IP Unknown! Learn more	
DKIM:	none Learn more	
DMARC:	temperror Learn more	

Analysis: This email is a critical threat that utilizes the "Livelo" brand to create urgency.

Key Indicators:

- **Authentication Failure:** The **Google Messageheader** reveals an **SPF/DMARC "temperror,"** meaning the sender's identity cannot be validated.
- **Domain Mismatch:** The display name says "Bradesco," but the actual sending address is a generic Brazilian domain (atendimento.com.br).

Risk Classification: CRITICAL. The goal is to steal banking credentials via a malicious link.

Sample 100: Marketing/Lead Phishing

Google Admin Toolbox Messageheader		Help
MessageId	0.0.0.0.1D8EF409A5C12CE.37AA@dturm.de	
Created at:	11/3/2022, 6:56:15 AM GMT+2 (Delivered after)	
From:	"Zonnepanelen installateur" <zonnepaneel@apojj.serenitepure.fr>	
To:	phishing@pot	
Subject:	Zonnepanelen voor een goede prijs	
SPF:	none	Learn more
DKIM:	none	Learn more
DMARC:	none	Learn more

#	Delay	From	To	Protocol	Time received
0		V11EUR05FT048.eop-eur05.prod.protection.outlook.com	→ AM7PR02CA0005.outlook.office365.com		11/3/2022, 6:56:15 AM GMT+2

Analysis: This email targets current concerns regarding electricity prices to lure users into clicking a tracking link.

Key Indicators:

- **Lack of Security Signatures:** The **DKIM** status is listed as "none," which is unusual for a legitimate service provider.
- **Suspicious Routing:** The **MessageId** shows the email originated from dturm.de, which does not match the advertised service.

Risk Classification: HIGH. It leads users to a suspicious redirect domain (go.nltrck.com).

Sample 1013: Social Engineering / Advance Fee Fraud

Google Admin Toolbox Messageheader					
MessageId	481485b6-1e17-4ac0-aa95-77fd08bac8b8@DM6NAM10FT113.eop-nam10.prod.protection.outlook.com				
Created at:	8/1/2023, 6:09:24 PM GMT+2 (Delivered after 26 sec)				
From:	shore@suksapan.or.th				
To:	Recipients <shore@suksapan.or.th>				
Subject:	Hi				
SPF:	softfail with IP Unknown! Learn more				
DKIM:	none Learn more				
DMARC:	none Learn more				

#	Delay	From *	To *	Protocol	Time received
0	14 sec	[102.69.133.254]	→ host4.ns.co.th		8/1/2023, 6:09:38 PM GMT+2
1	5 sec	DM6NAM10FT113.eop-nam10.prod.protection.outlook.com	→ DM6PR07CA0098.outlook.office365.com		8/1/2023, 6:09:43 PM GMT+2

Analysis: This sample is a classic "419" or inheritance scam that uses emotional manipulation rather than technical lures like fake bank portals.

Key Indicators:

- **SPF "Softfail":** The **Google Messageheader** shows an SPF **softfail**, indicating that the sending IP address (202.129.206.234) is not authorised to send mail on behalf of the suksapan.or.th domain.
- **Authentication Failure:** The **DMARC** status is "none" and the overall **compauth** resulted in a failure, proving the email is spoofed.
- **Reply-To Mismatch:** While the email claims to be from an official Thai educational domain, the "Reply-To" address is a generic **personal Gmail account** (elizabethray993@gmail.com).

Risk Classification: HIGH. The objective is to initiate a conversation that eventually leads to financial fraud or identity theft.

Prevention & Awareness Guidelines

The "Do's" for Employees

- **Analyse the Sender Address:** Always inspect the actual email address in brackets, not just the display name (e.g., "Bradesco"), as names are easily spoofed.
- **Hover Before You Click:** Hover your cursor over any hyperlink or button to preview the destination URL in the bottom-left corner of your browser.
- **Verify Internal Requests:** If you receive an urgent request from an "Executive" or "HR," verify the request through a secondary channel like a phone call or internal chat.
- **Enable Multi-Factor Authentication (MFA):** Ensure MFA is active on all corporate accounts to provide a second layer of security even if credentials are stolen.

The "Don'ts" for Employees

- **Don't Fall for Urgency:** Be wary of emails that use fear-based language like "Account Locked" or "Expiring Today" to bypass your critical thinking.
- **Don't Provide Sensitive Data on Unfamiliar Sites:** Never enter your password, OTP, or financial details on a website you accessed via an unsolicited email link.
- **Don't Download Unexpected Attachments:** Invoices or policy updates you were not expecting should be treated with extreme caution as they may contain malware.

Conclusion

The analysis of **Samples 1, 100, and 1013** highlights that while technical defences (like SPF and DMARC) are essential, they are not infallible. Attackers frequently exploit the "human element" through social engineering and emotional manipulation.

As a result of this audit, it is recommended that the organisation implements:

- Regular security awareness training for all staff.
- Stricter email filtering rules to block messages failing authentication checks.
- A clear reporting procedure so employees can alert the IT Security team to potential threats.

By fostering a "security-first" culture, the organisation can significantly reduce its risk of falling victim to phishing and credential harvesting.